SYSTEM-LEVEL SOFTWARE DESIGN SPECIFICATION

TokTickIT Ticketing Application

CPE 334 Software Engineering Course Project

Document status: Approved v1.0 system-wide design baseline. D-01 through D-12 have been confirmed and are binding on feature-level specifications unless changed through design review.

Document Control	Value
Document ID	SDS-SYS-001
Version	1.0 Approved
Prepared	17 August 2026
Method	Spec-Driven Development (SDD)
Design level	System-wide architecture and cross-cutting standards
Feature designs	Maintained separately and required to reference this SDS

Design objective

Provide one authoritative system design baseline so that students, instructors, and coding agents implement features consistently without repeatedly deciding architecture, security, data, API, UI, testing, and deployment conventions.

Decision Register

The decisions below are approved and used throughout this SDS. Any later change must be recorded here and propagated to affected feature specifications, tests, and implementation tasks.

ID	Decision	Approved baseline	Status
D-01	Official product spelling	TokTickIT	Approved
D-02	Ticket status vocabulary	New, Assigned, In Progress, Pending Requester, Resolved, Closed, Cancelled; any authorized user may cancel or reopen	Approved
D-03	Priority vocabulary	Low, Medium, High, Urgent for Requested Priority and IT Priority	Approved
D-04	Authentication session design	Opaque server-side session stored in PostgreSQL; Secure, HttpOnly, SameSite=Lax cookie	Approved
D-05	Account provisioning and password reset	Administrator creates the account and initial password; credentials and replacements are conveyed manually; no email reset	Approved
D-06	Attachment storage	SeaweedFS weed mini on the same server; S3-compatible adapter; PostgreSQL stores metadata only	Approved
D-07	Notification channels	In-app indicators only; no email integration	Approved
D-08	Deployment topology	One local server runs the application, PostgreSQL, and SeaweedFS	Approved
D-09	Branding and theme	KMUTT website/application palette with accessibility-safe derived interaction colors	Approved
D-10	Ticket number	TKT-YYYY-NNNNN, generated transactionally with an annual sequence reset	Approved
D-11	Retention and recovery	No ticket hard deletion; daily backups retained 7 days; deleted attachment binary removed immediately	Approved
D-12	Runtime and library versions	Use course-approved current stable/LTS majors; pin exact versions and the lockfile before Sprint 1	Approved

Document Map

- Purpose, scope, assumptions, and design principles
- Architecture, technology stack, deployable structure, and shared components
- Data architecture, security, roles, workflow invariants, APIs, and UI standards
- Attachments, auditability, NFR realization, deployment, testing, and feature-specification governance
- References and glossary

Purpose and Scope

Purpose

This System-Level SDS defines the design decisions that apply across every TokTickIT feature. It is the stable design baseline between the Software Requirements Specification (SRS) and the feature-level design specifications. It defines how the system is structured and how shared concerns are handled; it does not replace detailed feature behavior, screens, APIs, acceptance criteria, or test cases.

Intended Audience

- Students implementing the application in a team using GitHub and coding agents
- Instructors and teaching assistants reviewing design consistency and engineering deliverables
- Developers authoring feature specifications, database migrations, APIs, UI components, and tests
- Reviewers verifying traceability from SRS requirements to implemented and tested behavior

System Scope

The design supports an internal IT service ticketing application with these system-wide capability groups:

- Email/password authentication and role-based access control
- Ticket creation, categorization, priority, ownership, status workflow, resolution, and closure
- Service Actions with assignees and a lifecycle separate from the Ticket Owner
- Attachments with controlled upload and audited removal
- Immutable ticket event history for material actions and changes
- Search, filtering, dashboards, and administrative reference data
- Automated tests, CI/CD, and deployment to one local server

Out of Scope for the System-Level SDS

- Complete page wireframes and feature-specific interaction sequences
- Exact endpoint payloads for every feature
- Sprint backlog, effort estimates, and grading rubrics
- External SLA, procurement, CMDB, asset management, chat, or AI support capabilities unless added to the SRS

Design Basis

This approved baseline preserves the following course and application decisions:

- Frontend: React, TypeScript, Vite, and Bootstrap
- Backend: Node.js, Express, and TypeScript
- Database: PostgreSQL with Prisma ORM and migrations
- Architecture style: REST-style APIs and logical three-tier architecture
- Roles: Requester, IT Staff, and Administrator. The role name Agent is not used.
- Testing: Vitest, Supertest, and Playwright
- Workflow: Git, GitHub Issues/Projects, pull requests, and GitHub Actions
- Deployment target: one local server running the application, PostgreSQL, and SeaweedFS

Design Principles

1. Trace every system behavior to an approved requirement, business rule, NFR, or design decision.
2. Keep business rules in backend domain services so UI code cannot bypass them.
3. Use database transactions for state changes that must be accompanied by an event record.
4. Apply least privilege and deny access by default.
5. Prefer one clear, course-appropriate implementation over unnecessary infrastructure complexity.
6. Design for automated testing at unit, API integration, and browser end-to-end levels.
7. Keep the system-level rules stable; feature specifications may extend but may not contradict them.

System Architecture

Architecture Style

TokTickIT uses a logical three-tier architecture. The presentation tier contains the React SPA. The application tier contains Express routing, authentication, authorization, validation, and domain services. The data tier contains PostgreSQL and SeaweedFS object storage. All tiers are deployed on one local server for the course labs while retaining separate code and service responsibilities.

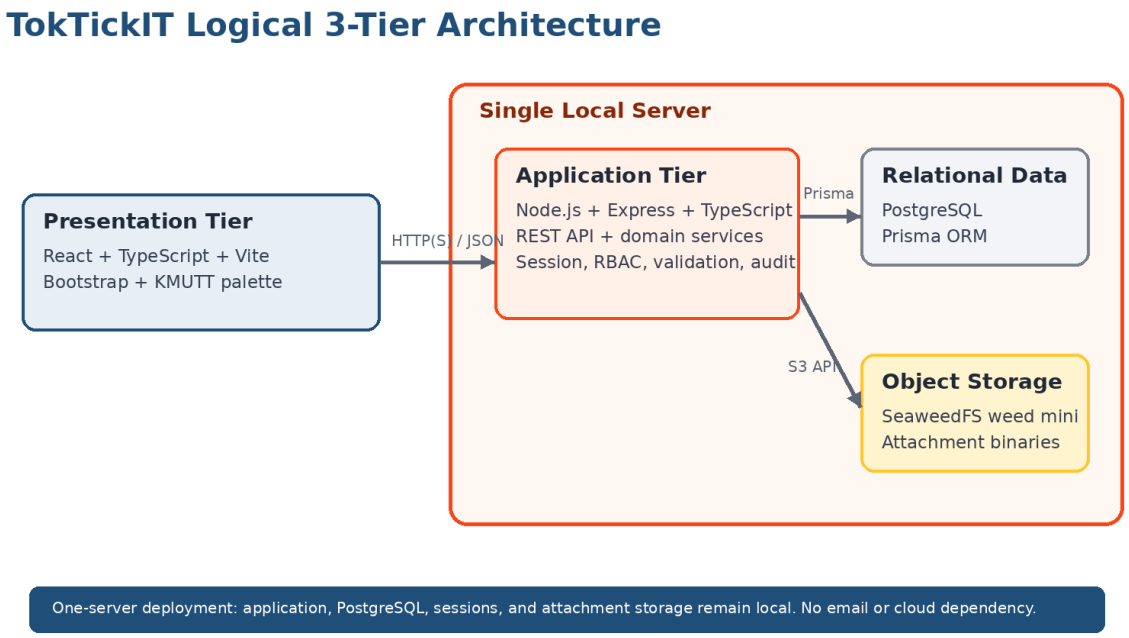

Figure 1. Approved logical and single-server architecture

Approved Decision D-08: The lab deployment uses one local server. The Express process serves the compiled SPA and /api/v1, while PostgreSQL and SeaweedFS run as local services on the same host.

Deployment Units

Deployable/Service	Implementation	Responsibility
Web application	Compiled React SPA served as static assets by Express	Browser presentation tier
Application API	Express routes under /api/v1 plus domain services	Application tier
Relational database	PostgreSQL on the local server	Transactions, constraints, system records, and sessions
Object storage	SeaweedFS weed mini on the local server	Attachment binaries; metadata remains in PostgreSQL
CI/CD	GitHub Actions to the local server	Build, test, migrate, deploy, and smoke test

Technology Stack

Layer	Technology	System-level use
Language	TypeScript	Shared type discipline; no direct sharing of persistence models with public API contracts
Frontend	React + Vite + Bootstrap	Component UI, routing, forms, accessible responsive layout
Backend	Node.js + Express	REST API, sessions, RBAC, validation, orchestration
Persistence	PostgreSQL + Prisma	Relational integrity, migrations, transactions, typed data access
Unit/API testing	Vitest + Supertest	Domain and endpoint verification
E2E testing	Playwright	User-visible workflows in a real browser
Object storage	SeaweedFS + S3-compatible client	Local attachment storage behind an application adapter
Delivery	GitHub Actions + single server	Repeatable test and deployment pipeline

Repository Structure

```
client/              React application and UI components
server/              Express API, middleware, domain services
server/prisma/       Prisma schema, migrations, and seed data
shared/              API contract types and shared constants only
tests/e2e/           Playwright tests
.github/workflows/   CI/CD pipelines
docs/specs/          SRS, System-Level SDS, and feature specifications
```

Shared Components and Boundaries

Component	Responsibility	Boundary rule
Web UI	Routes, forms, tables, dashboards, accessible feedback	Calls only published API contracts
API Controller	HTTP parsing, status codes, DTO mapping	Contains no core business rules
Authentication	Login, logout, session validation, password verification	Produces authenticated user context
Authorization	Role and resource ownership checks	Enforced server-side on every protected operation
Ticket Domain Service	Ticket lifecycle, owner, priorities, resolution rules	Owns ticket invariants and transactions
Service Action Service	Action lifecycle and assignee rules	Enforces action state transitions
Attachment Service	Validation, object storage, audited removal	Never exposes raw storage keys to clients
Notification Service	Creates and reads in-app notification indicators	No email provider or outbound delivery dependency
Audit/Event Service	Append-only event creation and retrieval	Events created in the same transaction as changes
Repositories	Prisma queries and persistence mapping	No HTTP concerns

Domain Data Model

All primary entities use UUID identifiers. Human-readable ticket numbers are separate unique values. Timestamps are stored in UTC using PostgreSQL timestamptz. Prisma enums express the approved status and priority vocabularies from D-02 and D-03.

Entity	Important fields	System-level rule
User	id, email, passwordHash, displayName, role, isActive, createdAt, updatedAt	Email unique; role is Requester, IT Staff, or Administrator
Ticket	id, ticketNo, title, description, requesterId, ownerId, categoryId, requestedPriority, itPriority, status, resolutionSummary, requesterResolutionConfirmedAt, version, timestamps	Requester required; owner nullable until assignment; optimistic version increments on updates
Category	id, code, name, description, isActive	Inactive categories remain referenced by historical tickets
ServiceAction	id, ticketId, title, description, assigneeId, status, dueAt, completionNote, timestamps	Status is Planned, In Progress, Completed, or Cancelled
Attachment	id, ticketId, uploadedById, originalFilename, mimeType, sizeBytes, storageKey, deletedAt, deletedById	Binary stored in local SeaweedFS; deleted row becomes a tombstone
Notification	id, userId, ticketId, type, message, readAt, createdAt	In-app only; unread count is derived from readAt

Entity	Important fields	System-level rule
TicketEvent	id, ticketId, actorId, eventType, payloadJson, createdAt	Append-only; payload stores audit detail appropriate to event type
Session	id, userId, expiresAt, revokedAt, metadata	Stores the approved opaque server-side sessions from D-04

Relationship and Integrity Rules

- A User may request many Tickets and may own many Tickets if the user is IT Staff or Administrator.
- A Ticket has zero or more Service Actions, Attachments, Notifications, and Ticket Events.
- A Service Action assignee may differ from the Ticket Owner.
- Tickets and Ticket Events are never cascade-deleted. Foreign-key deletion is restricted for historical records.
- Users and Categories use activation flags rather than hard deletion when referenced.
- Ticket creation, ticket transitions, priority changes, ownership changes, and attachment removal each write an event in the same database transaction as the business change.

Concurrency and Transactions

- Ticket updates use an integer version field. A stale update returns HTTP 409 Conflict rather than overwriting newer work.
- Ticket numbers are generated transactionally so concurrent creates cannot produce duplicates.
- Multi-record business changes use Prisma transactions.
- Object storage operations use compensating cleanup when a database transaction cannot include the external file operation.

Security Architecture

Authentication

Users authenticate with email and password. Passwords are never stored or logged in plaintext. The recommended algorithm is Argon2id using a maintained Node.js library and parameters benchmarked for the deployment environment, following OWASP guidance [R1].

- Email comparison is case-insensitive and normalized before uniqueness checks.
- Login responses do not reveal whether an email address exists.
- Repeated failed logins are rate-limited and security-relevant failures are logged without credentials.
- Passwords are accepted as Unicode and are never silently truncated.
- Administrators create accounts and initial passwords, convey credentials manually, and set replacement passwords when needed. No email-based password reset is implemented.

Approved Decisions D-04 and D-05: Use server-side PostgreSQL sessions. Administrators provision accounts and passwords, and all credential delivery occurs outside the application.

Session Management

The system stores an opaque session identifier in a Secure, HttpOnly, SameSite=Lax cookie and stores session state in PostgreSQL. Session identifiers rotate after login and privilege changes. Logout and an administrator-set password replacement revoke active sessions. Cookie flags and session expiration follow OWASP session-management guidance [R2].

- Idle timeout: 30 minutes. Absolute timeout: 8 hours.
- State-changing requests require CSRF protection when cookie authentication is used.
- The production application is HTTPS-only and sets HSTS at the edge.
- Client JavaScript never reads the session token.

Authorization Model

Authorization combines role checks with resource-level rules. The backend is authoritative; hiding a UI control is not authorization.

Capability	Requester	IT Staff	Administrator
Create a ticket	Yes	Yes	Yes
View tickets	Own/requested tickets	All tickets	All tickets
Set or change IT Priority	No	Yes	Yes
Set Resolved or Closed	No	Yes	Yes
Cancel an accessible ticket	Yes	Yes	Yes
Reopen an accessible ticket	Yes	Yes	Yes
Assign Ticket Owner	No	Yes	Yes
Create/manage Service Actions	No	Yes	Yes
Delete own attachment before Closed	Yes	Yes	Yes
Delete another user's attachment	No	Yes, with reason	Yes, with reason
Manage users, roles, categories	No	No	Yes
View security/administrative audit	No	Restricted	Yes

Input and Output Security

- Validate all request payloads at the API boundary and enforce database constraints independently.
- Use Prisma parameterization; never construct SQL with untrusted string concatenation.
- React renders user content as text by default. Raw HTML rendering is prohibited unless sanitized by an approved library.
- Production errors return safe messages and correlation IDs, not stack traces or database details.
- Secrets are injected from protected server environment configuration and never committed to Git.

Cross-Feature Workflow Rules

Ticket Status Baseline

Status	Meaning	Invariant
New	Created and not yet formally assigned	Owner may be empty
Assigned	Ticket Owner has accepted responsibility	Owner required
In Progress	Work is actively underway	Owner required
Pending Requester	IT needs requester input or verification	Owner remains responsible
Resolved	IT Staff has formally resolved the ticket	All Service Actions completed/cancelled; any authorized user may reopen
Closed	Work is complete and locked	No normal modification until an authorized user reopens
Cancelled	Ticket will not be completed	Reason required; any authorized user may reopen

Approved Decision D-02: Any authenticated user with read access to a ticket may cancel it from any non-Cancelled status or reopen it from Resolved, Closed, or Cancelled. Every cancellation and reopening is confirmed and recorded as a Ticket Event.

Mandatory Ticket Invariants

- Only IT Staff or Administrator changes the formal ticket status to Resolved or Closed.
- Any authenticated user with read access to a ticket may cancel or reopen it. A Requester therefore acts only on tickets they are authorized to view; IT Staff and Administrators may act on all tickets.
- Cancellation requires a reason and atomically changes any Planned or In Progress Service Actions to Cancelled using the same reason.
- Reopening changes the ticket to In Progress when a Ticket Owner exists, otherwise to New. Previously cancelled Service Actions remain Cancelled; new work requires new Service Actions.
- The Requester may indicate that the problem appears resolved or confirm resolution, but this records a confirmation flag/event and does not directly change formal status.
- If requester confirmation exists while open Service Actions remain, the Ticket Owner is warned and the ticket stays in its current status.
- A ticket cannot move to Resolved or Closed while any Service Action is Planned or In Progress.
- Before resolution, every Service Action must be Completed or Cancelled.
- Ticket Owner responsibility is separate from Service Action assignment.

- Requested Priority belongs to the Requester. IT Priority is controlled by IT Staff or Administrator. IT Priority may initially copy Requested Priority.
- All changes to IT Priority are recorded in the Ticket Event log.

Service Action Lifecycle

Status	Meaning	Allowed next states
Planned	Defined but not started	In Progress, Cancelled
In Progress	Actively being performed	Completed, Cancelled
Completed	Finished with completion evidence	Terminal
Cancelled	No longer required; reason recorded	Terminal

API Design Standards

- All application endpoints are rooted at /api/v1.
- Requests and responses use JSON except multipart attachment upload and file download.
- Property names use camelCase. Database naming may use snake_case through Prisma mapping.
- Dates and times use ISO 8601 UTC strings. Display localization occurs in the client.
- Collection endpoints support pagination, explicit filtering, and a constrained sort whitelist.
- Successful create operations return HTTP 201; validation errors 422; authentication failures 401; authorization failures 403; missing resources 404; stale updates 409.
- API contracts use DTOs. Prisma models are never serialized directly.

```
{
  "error": {
    "code": "TICKET_STATE_CONFLICT",
    "message": "Ticket cannot be resolved while service actions remain open.",
    "fieldErrors": [],
    "correlationId": "..."
  }
}
```

Validation and Error Handling

- Client validation improves usability but never substitutes for API validation.
- Validation schemas are reusable at API boundaries and return stable machine-readable error codes.
- Domain-rule failures are distinct from input-format failures.
- Unexpected exceptions are logged with a correlation ID and mapped to a generic HTTP 500 response.

- The UI preserves user input after recoverable errors and clearly identifies fields requiring correction.

Frontend and UI Design System

Frontend Structure

- Route components orchestrate feature pages; reusable components remain presentation-focused.
- API access is centralized in typed service modules rather than called directly from arbitrary components.
- Authentication state and current-user role are exposed through one application-level context.
- Server state is refreshed after mutations; the client does not assume a status change succeeded.
- The application header displays an unread in-app notification count and opens a notification list where items can be marked read. No email notification control is shown.
- Permission-sensitive controls are hidden or disabled for usability, while the server still enforces permission.

KMUTT Theme Tokens

Token	Value	Use
KMUTT orange	#FA4616	Brand accents and primary-action background with dark text
KMUTT yellow	#FFC72C	Secondary accents, focus ring, and warning surfaces with dark text
KMUTT blue grey	#7B8189	Borders, icons, and non-text decorative elements
Interactive dark orange	#8A2608	Accessible links, active navigation, and focus emphasis on light backgrounds
Text	#1F2937	Primary text
Muted	#5B6573	Secondary labels and metadata
Background	#FFFFFF	Application background
Success	#2E7D32	Completed/success state, always with text/icon
Danger	#B3261E	Destructive/error state, always with text/icon

Approved Decision D-09: TokTickIT uses KMUTT's official website/application colors: Orange #FA4616, Yellow #FFC72C, and Blue Grey #7B8189 [R6]. Derived dark orange is permitted where the official colors do not provide sufficient text contrast.

System-Wide UI Standards

- Use the system font stack with Bootstrap's responsive grid and spacing scale.
- Use one shared component treatment for forms, buttons, tables, badges, confirmation dialogs, loading, empty, and error states.
- Do not communicate status or priority by color alone. Include text and, where useful, an icon.
- Every form control has a programmatic label; validation messages are associated with the field.
- Keyboard focus is visible and logical. Dialogs trap focus and return it to the invoking control.
- Target WCAG 2.2 Level AA [R4]. Feature specifications must identify any justified exception.
- Use Bootstrap breakpoints unless a feature specification documents a stronger layout need.
- Dates display in the user's locale but are transported and stored in UTC.

Attachment Architecture

Both Requesters and IT Staff may add attachments when ticket permissions and status permit. The uploader may delete their own attachment while the ticket is not Closed. IT Staff or Administrators may remove an attachment when necessary. Every removal requires confirmation and creates an ATTACHMENT_REMOVED event with filename, uploader, remover, reason, and timestamp.

Upload Controls

- Limit: 5 MB per file and no more than 5 active files per ticket.
- Allowed extensions and MIME types: JPG, PNG, WEBP, and PDF only.
- Validate extension, detected content type, declared MIME type, size, and authorization. Rename stored objects to generated identifiers.
- Do not execute, render as HTML, or serve attachments inline with an attacker-controlled content type.
- Use authenticated download endpoints that authorize the user before streaming an object from SeaweedFS.
- Apply layered upload controls following OWASP file-upload guidance [R3].

Removal and Audit Sequence

1. Authorize the remover and verify the ticket is not Closed unless an Administrator override is permitted.
2. Require confirmation and a removal reason.
3. Mark the Attachment metadata as deleted and create ATTACHMENT_REMOVED in one database transaction.

4. Delete the object from storage. If deletion fails, queue or record a retry without restoring user visibility.
5. Display the removal event in the authorized ticket history while never exposing the deleted object key.

Event and Audit Model

- Ticket Events are append-only and are never edited through normal application APIs.
- Events record actor, event type, timestamp, and the minimum structured before/after detail needed for accountability.
- Passwords, session IDs, reset tokens, attachment content, and unrelated personal data never enter event payloads.
- Material events include ticket creation, ownership change, status change, IT Priority change, requester resolution confirmation, Service Action lifecycle change, attachment addition/removal, and administrative changes.
- Operational logs and business events are separate. Operational logs support diagnosis; Ticket Events support domain history.

Non-Functional Design Realization

The SRS owns the authoritative NFR values. The targets below are the approved engineering baseline for feature design; an approved NFR change takes precedence and must be propagated to this SDS.

Quality	Target	Design response
Performance	p95 API response under 500 ms for normal CRUD at 50 concurrent users; uploads excluded	Indexes, pagination, query review, payload limits, performance smoke test
Availability	Best effort course service; no contractual SLA	Health endpoint and restartable local services
Scalability	Single-server course deployment	Bounded pagination, indexed queries, attachment limits, monitored disk capacity
Security	Least privilege, secure password/session handling, dependency review	RBAC, CSRF, rate limiting, secrets management, CI checks
Accessibility	WCAG 2.2 AA target	Semantic HTML, keyboard support, contrast, Playwright/a11y checks
Maintainability	Clear layer boundaries and typed contracts	Lint, formatting, code review, migrations, domain services
Auditability	All material ticket changes traceable	Append-only TicketEvent written transactionally
Recoverability	Daily backups retained 7 days	PostgreSQL dump plus SeaweedFS data backup and documented restore exercise

Quality	Target	Design response
Privacy	Collect only data needed for service delivery	Access control, log redaction, retention decision, no hard delete of audit history

Observability

- Write structured JSON logs in production with timestamp, severity, correlationId, route, outcome, and safe user/ticket identifiers where appropriate.
- Expose /health for process health and a protected readiness check for database connectivity.
- Record latency and error counts by route without logging request bodies by default.
- Use one correlation ID across HTTP response, operational logs, and background work.
- Alerting thresholds and notification recipients are deployment-environment configuration, not code constants.

Configuration and Secrets

- Maintain separate development, test, staging, and production configuration.
- Validate required environment variables at startup and fail fast with a safe message.
- Store server secrets in a protected environment file or service configuration readable only by the deployment account.
- Commit an .env.example containing names and safe examples only.
- Never use production credentials or production data in automated tests.

CI/CD and Deployment

Every pull request and protected-branch deployment follows a reproducible pipeline.

1. Install from the committed lockfile.
2. Run formatting and lint checks.
3. Run TypeScript compilation/type checking.
4. Run unit and API integration tests against an isolated PostgreSQL database.
5. Build the React application and the deployable Node.js application artifact or container.
6. Run Playwright smoke tests in an environment suitable for browser execution.
7. Back up the local PostgreSQL database and active SeaweedFS data before a production migration.
8. Apply reviewed Prisma migrations using a controlled deployment step.
9. Deploy the same tested artifact to the local server, restart only affected services, and run smoke tests.

Database Migration Rules

- Every schema change is represented by a committed Prisma migration.
- Migrations are reviewed with the feature pull request and tested from a clean database plus the previous baseline.
- Destructive migration requires an explicit data-migration or rollback plan.
- Application and migration order must preserve backward compatibility during deployment where practical.
- Production migration credentials are separate from ordinary application credentials when feasible.

Testing Architecture

Level	Tool	Primary coverage	Boundary
Unit	Vitest	Pure domain rules, validators, mappers, utilities	Fast; no network or real database
API integration	Vitest + Supertest	Routes, middleware, RBAC, transactions, Prisma repositories	Isolated PostgreSQL test database
Browser E2E	Playwright	Critical Requester, IT Staff, and Administrator workflows	Runs against deployed or local full stack
Migration	Prisma + test database	Clean install and upgrade from prior schema	Required for schema-changing PRs
Security	Automated checks + focused tests	Authorization regression, upload rejection, session/CSRF behavior	Required for protected operations

Mandatory Business-Rule Tests

- Requester cannot directly set Resolved or Closed.
- Open Service Actions prevent resolution and closure.
- Requester resolution confirmation is recorded without bypassing open actions.
- Each role may cancel or reopen only a ticket it is authorized to view; both actions require confirmation and create audit events.
- Cancelling a ticket atomically cancels its Planned and In Progress Service Actions; reopening selects In Progress when an owner exists and New otherwise.
- Only IT Staff or Administrator changes IT Priority after creation.
- Ticket Owner and Service Action Assignee may differ.
- Attachment removal permissions, ticket-state restriction, confirmation, reason, binary deletion, and event creation behave as specified.

- All protected endpoints reject unauthorized access even when called outside the UI.

Line coverage is a diagnostic metric, not a substitute for these behavior tests. A feature is not complete when its critical business rules are untested.

Feature Specification Contract

Each feature-level design specification inherits this System-Level SDS. A feature specification documents only its feature-specific behavior and design choices, while referencing rather than duplicating shared rules.

Section	Required content
Identity	Feature ID, name, purpose, owner, version, status
Traceability	Related BR, FR, NFR, business-rule, and decision IDs
Behavior	Actors, preconditions, main flow, alternatives, errors, acceptance criteria
Permissions	Role and resource-level access, including denial cases
Workflow	State transitions and system invariants affected
Data	Entities/fields changed, migration, constraints, transaction boundaries
API	Endpoints, DTOs, status codes, errors, pagination/filtering where relevant
UI	Routes, components, states, validation, accessibility, responsive behavior
NFRs	Applicable system targets plus feature-specific targets
Testing	Unit, integration, E2E, security, and acceptance test obligations
Dependencies	Other features, reference data, integrations, configuration
Out of scope	Explicit exclusions to prevent coding-agent assumptions

Specification Precedence

1. Approved SRS requirements and business rules define what must be achieved.
2. This System-Level SDS defines shared design decisions and constraints.
3. An approved feature specification defines feature-specific behavior and design.
4. Implementation tasks divide the approved feature specification into work items.
5. Automated and acceptance tests verify the specifications.

Conflict rule: A feature specification may extend this SDS but may not silently contradict it. Resolve conflicts through an approved SDS decision change and update traceability before implementation.

Definition of Ready for Implementation

- The feature maps to approved requirements and has no unresolved business ambiguity.

- Applicable system-level decisions are approved, and any proposed deviation has an approved design-change record.
- Behavior, permissions, data, API, UI states, error handling, and acceptance criteria are defined.
- Dependencies and migration implications are understood.
- The test obligations are concrete enough to write before or alongside implementation.
- A developer or coding agent can implement without inventing important business rules.

Traceability and Change Control

- Maintain a matrix from SRS requirement IDs to feature IDs, feature specification versions, pull requests, and test IDs.
- Record system-level changes in this document's Decision Register and version history.
- Do not alter an approved shared enum, role, workflow invariant, API convention, or data-lifecycle rule in one feature only.
- Pull requests reference the implementing issue and feature specification. Issue and pull-request numbers are independent identifiers.
- Architecture-significant changes require instructor or designated design-review approval before merge.

System-Level Review Checklist

Review area	Pass condition
Architecture	Layer boundaries and deployable topology remain consistent
Security	Authentication, authorization, session, upload, and secret rules are followed
Data	Constraints, migrations, transactions, audit events, and deletion behavior are defined
API	Versioning, DTOs, status codes, validation, and error envelope are followed
UI	Shared theme, components, responsive behavior, and accessibility are followed
Testing	Critical business rules are verified at the appropriate test level
Traceability	Requirement, feature, issue, PR, and test links are present

References

ID	Reference	URL
R1	OWASP Password Storage Cheat Sheet	https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html

ID	Reference	URL
R2	OWASP Session Management Cheat Sheet	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html
R3	OWASP File Upload Cheat Sheet	https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html
R4	W3C Web Content Accessibility Guidelines (WCAG) 2.2	https://www.w3.org/TR/WCAG22/
R5	SeaweedFS README and weed mini Quick Start	https://github.com/seaweedfs/seaweedfs/blob/master/README.md
R6	KMUTT Corporate Identity: Colors	https://www.kmutt.ac.th/en/corporate_identity/colors/

Glossary

Term	Meaning
BR	Business Requirement
FR	Functional Requirement
NFR	Non-Functional Requirement
SRS	Software Requirements Specification
SDS	Software Design Specification
SDD	Spec-Driven Development in this course
Requester	User who requests IT support and may confirm that a problem appears resolved
IT Staff	Role responsible for formal ticket workflow and service work
Administrator	Role with IT Staff authority plus system administration
Ticket Owner	IT Staff or Administrator accountable for the ticket as a whole
Service Action Assignee	Person assigned to an individual Service Action; may differ from Ticket Owner
Ticket Event	Append-only business audit record associated with a ticket

Approval Status

This v1.0 document is the approved System-Level SDS. D-01 through D-12 are resolved. Every feature specification must inherit this baseline and reference the applicable SRS requirements, feature ID, business rules, and tests.

Next action: Complete or validate the Feature Inventory and then prepare feature-level specifications in dependency order, beginning with authentication, users/roles, reference data, and ticket creation.